

DEVSECOPS LAB BOOK · EDITION 2026

Phase 4: CI/CD Supply Chain

COMPLETE

Eight chapters, from source control to signed, attested, compliant delivery. Every artifact traced, every gate enforced, every step audited.

8	360+	230+	90K+
Chapters	Pages	Advanced pgs	Words

CHAPTER SUMMARY

Eight chapters, one hardened delivery pipeline

13	**GitLab CE**	Source control + CI/CD	✓
14	**SonarQube**	Code quality (SAST)	✓
15	**Harbor**	Container registry	✓
16	**DefectDojo**	Vulnerability management	✓
17	**CI/CD Pipeline**	End-to-end orchestration	✓
18–19	**Supply Chain & Compliance**	SLSA, SBOM, attestation	✓

COMPLETE ARCHITECTURE

How the eight chapters fit together



Foundation (Ch. 13–15) — GitLab · SonarQube · Harbor



Orchestration (Ch. 17) — Complete CI/CD pipeline, end to end



Management (Ch. 16) — DefectDojo vulnerability management



Security & Compliance (Ch. 18–19) — SLSA · signing & attestation · SBOM · SLA tracking · SOC2/PCI/HIPAA reporting

Result: secure, auditable, compliant software delivery — every artifact traced from source to deployment.

COMPLETE PIPELINE

From commit to compliant deployment

1. Developer commits & pushes to GitLab
2. CI/CD builds, tests, runs SonarQube SAST — quality gate must pass
3. Docker image built & pushed to Harbor
4. Harbor scans image with Trivy — DefectDojo imports findings
5. Manual approval gate · image signed & attested
6. SBOM generated · compliance & SLA checks run
7. Kubernetes pulls the image via Teleport — secrets from Vault
8. Complete audit trail recorded end to end

PROJECT STATISTICS

All four phases, combined

20	**935+**	**390K+**	**800+**
Chapters (0–19)	Pages	Words	Code examples
120+	**15+**	**80+**	**300–400 hrs**
Config files	Validation scripts	Diagrams	Time to lab

PHASE-BY-PHASE

What each phase delivers

1

Foundation

6 ch · 290 pg

Secure infrastructure from the ground up — DNS, identity, TLS, authentication, all manually configured

2

Automation

3 ch · 150 pg

Reproducible infrastructure — Packer → OpenTofu → Ansible, deployable in 30 minutes

3

Security & Access

3 ch · 135 pg

Centralized secrets, automatic certificate issuance, zero-trust access with session recording

4

CI/CD Supply Chain

8 ch · 360 pg

Source control, automated scanning, container registry, complete compliance & audit framework

SKILLS MATRIX

Capabilities earned across the lab book

Infrastructure & Networking

Virtual networking · DNS · Load balancing · Reverse proxying · TLS/HTTPS

Identity & Access

LDAP · OAuth2/OIDC · Zero-trust access · Session recording · RBAC

Secrets & Certificates

Secrets management · PKI · Auto-renewal · Key rotation · Token lifecycle

Infrastructure Automation

Golden images · IaC · Configuration management · IaC testing

Source Control & CI/CD

Git workflows · Pipelines · Code review · Docker builds · Orchestration

Code Quality & Security

SAST · Vulnerability scanning · Dependency analysis · Coverage · Quality gates

Container Security

Image registry · Image scanning · Image signing · Vuln management · SBOM

Supply Chain & Compliance

SLSA framework · Provenance attestation · Compliance reporting · Incident response

COMPLETE DEVOPS CAPABILITIES

What the lab can do now

Immediate

- Deploy infrastructure in 30 minutes
- Secure code from commit to deployment
- Manage secrets centrally
- Control access with zero-trust
- Audit every action

Advanced

- Recover from disaster in 1 hour
- Scale multiple environments from the same code
- Enforce security at every gate
- Generate compliance reports automatically
- Investigate incidents from audit trails
- Track vulnerabilities to remediation

SECURITY POSTURE

Where every layer stands, after all four phases

Auth & Authorization

Centralized identity · OIDC everywhere · zero-trust · session audit

Secrets & Encryption

Centralized secrets · auto-rotation · TLS everywhere · auto-renewed certs

Code Security

Enforced review · SAST on every commit · dependency scanning · quality gates

Container Security

Private registry · Trivy scanning · image signing · prevention policies

Visibility & Compliance

Full audit trail · session recordings · vuln tracking · SOC2/PCI/HIPAA reporting

Supply Chain Security

SLSA framework · provenance attestation · SBOM · signing & verification

PROJECT COMPLETION STATUS

All four phases, delivered

✓ Phase 1 — Foundation	6 chapters
✓ Phase 2 — Automation	3 chapters
✓ Phase 3 — Security & Access	3 chapters
✓ Phase 4 — CI/CD Supply Chain	8 chapters

TOTAL: 20 chapters · 935+ pages · 390,000+ words

WHAT'S NEXT

Phase 5 and beyond

Phase 5 — Kubernetes & Orchestration

- → Kubernetes cluster setup
- → Helm deployments
- → Istio service mesh
- → GitOps with ArgoCD

Advanced Topics (Optional)

- → Disaster recovery & high availability
- → Multi-region failover
- → Backup & restore procedures
- → Performance optimization
- → Cost optimization



DEVSECOPS LAB BOOK — ZERO TO HERO

Complete DevSecOps Training Platform

20 chapters

935+ pages

390,000+ words

800+ code examples

120+ config files

15+ validation scripts

80+ diagrams

Ready for publishing, training, and enterprise use.

Phases 1–4 complete